REQUEST FOR PROPOSAL

Cyber Security Services & Managed Security Program

Insurance Domain | Sample / Fictional RFP

RFP Reference	INS-CYBER-2026-001
Issuing Organization	Meridian Insurance Group (fictional)
Issue Date	September 15, 2026
Proposal Due Date	October 16, 2026
Contract Term	3 years + two optional 1-year extensions

1. RFP Overview

Meridian Insurance Group invites qualified cyber security service providers to submit proposals for an enterprise cyber security program covering corporate IT, cloud workloads, customer-facing applications, insurance policy and claims platforms, endpoints, identities, third-party connections, and security operations.

The selected provider will improve threat prevention, detection, response, resilience, security governance, vulnerability management, and regulatory readiness while minimizing disruption to insurance operations.

2. Business Context

• The organization operates personal, commercial, and specialty insurance lines.

• Critical systems include policy administration, claims processing, billing, customer portals, agent/broker portals, data warehouses, APIs, and cloud services.

• Sensitive information includes customer identity data, policy information, claims records, payment information, employee information, and selected health-related or financial data.

• The organization uses a hybrid technology environment with cloud and on-premises infrastructure and relies on external technology and service providers.

3. Objectives

• Establish continuous enterprise security monitoring and incident response.

• Reduce exploitable vulnerabilities and improve remediation discipline.

• Strengthen identity, privileged access, endpoint, network, application, and cloud security.

• Protect sensitive insurance customer and claims data.

• Improve third-party and supply-chain cyber risk visibility.

• Support business continuity and cyber resilience for critical insurance services.

• Provide measurable security KPIs, risk reporting, and executive dashboards.

• Support audit and regulatory evidence collection.

4. Scope of Services

Service Area	Minimum Requirement
Security Operations / SOC	24x7 monitoring, alert triage, investigation, threat hunting, escalation, and incident coordination.

Service Area	Minimum Requirement
Incident Response	Incident response procedures, containment guidance, forensic support, root-cause analysis, and post-incident improvemer
Vulnerability Management	Continuous scanning, business-context prioritization, remediation tracking, and validation.
Endpoint Security	EDR/XDR coverage, endpoint telemetry, malware detection, isolation, and response.
Identity & Access	MFA, privileged access monitoring, identity threat detection, access reviews, and anomalous-login detection.
Cloud Security	Monitoring and posture management for cloud infrastructure, workloads, identities, storage, and configurations.
Application & API Security	Web application security, API security, secure SDLC support, testing, and remediation recommendations.
Data Security	Data discovery/classification support, DLP controls, encryption posture, key management, and sensitive-data access moni
Third-Party Risk	Security assessment of critical vendors, continuous monitoring, risk scoring, and remediation tracking.
Security Awareness	Role-based training, phishing simulations, reporting metrics, and targeted awareness programs.
Governance & Compliance	Security policies, control mapping, evidence support, risk registers, audit support, and management reporting.

5. Insurance-Specific Security Requirements

• Protect policyholder, claimant, agent, broker, employee, and business-partner information.

• Monitor privileged access to policy, claims, underwriting, billing, and customer-service systems.

• Detect unauthorized access or unusual data movement involving claims and customer records.

• Support incident-response scenarios affecting policy issuance, claims processing, payment operations, or customer portals.

• Assess cyber risks introduced by MGAs, brokers, TPAs, cloud providers, SaaS vendors, payment providers, and other critical third parties.

• Maintain evidence suitable for internal audit, external audit, risk committees, and applicable regulatory examinations.

• Provide controls for ransomware, credential theft, business email compromise, data exfiltration, API abuse, and supply-chain compromise.

6. Minimum Technical Requirements

• Centralized security event collection and correlation.

• Integration with identity, endpoint, firewall, cloud, vulnerability, ticketing, and collaboration platforms.

• Detection rules mapped to recognized adversary behaviors and continuously tuned.

• Automated enrichment using asset criticality, identity context, threat intelligence, and known vulnerabilities.

• Case management with complete investigation history and audit trail.

• Role-based access control and strong authentication for the security platform.

• Encryption in transit and at rest.

• Defined data retention, deletion, and customer-data handling procedures.

• High availability and documented disaster recovery for critical security services.

7. Service Levels

Severity	Example	Initial Acknowledgement	Escalation
Critical / P1	Confirmed active breach, ransomware, material data exfiltration	15 minutes	Immediate
High / P2	Credible compromise or high-risk security incident	30 minutes	Within 30 minutes
Medium / P3	Suspicious activity requiring investigation	4 hours	Same business day
Low / P4	Low-risk event or informational alert	1 business day	As required

8. Deliverables

• Implementation and transition plan.

• Security architecture and integration design.

• 24x7 monitoring and incident management service.

• Monthly operational report and quarterly executive risk report.

• Vulnerability and remediation reports.

• Third-party cyber-risk assessments.

• Incident-response playbooks and annual exercises.

• Security KPI/KRI dashboard.

• Annual service review and continuous-improvement roadmap.

9. Vendor Response Requirements

• Executive summary and understanding of insurance-sector requirements.

• Proposed solution architecture.

• Detailed response to every requirement in Sections 4–8.

• Implementation methodology and timeline.

• Service organization, staffing model, locations, and escalation structure.

• Relevant insurance-sector experience and references.

• Security certifications and independent assurance reports.

• Data residency, data processing, retention, and subcontractor model.

• Business continuity and disaster recovery approach.

• Pricing model, assumptions, exclusions, and optional services.

• Contract terms, service-level commitments, and proposed exceptions.

10. Mandatory Vendor Questionnaire

1. Describe how your SOC detects and investigates identity compromise.

2. How do you prioritize vulnerabilities using asset criticality and exploitability?

3. Describe your approach to ransomware detection and containment.

4. How do you protect and monitor cloud identities and privileged accounts?

5. How do you detect suspicious access to customer and claims data?

6. How do you handle third-party cyber-risk assessments and continuous monitoring?

7. Which SIEM, SOAR, EDR/XDR, vulnerability, threat-intelligence, and ticketing integrations are supported?

8. Describe your incident-response escalation process for a material insurance-sector cyber event.

9. How do you validate that alerts are supported by reliable evidence before escalating them?

10. What measurable KPIs and KRIs will you provide to executive management?

11. Evaluation Criteria

Evaluation Area	Weight	Evaluation Focus
Technical Capability	25%	Coverage, architecture, integrations, detection and response
Insurance / Industry Experience	15%	Relevant insurance-sector delivery and references
Security & Compliance	15%	Security controls, assurance, privacy, auditability
Service Quality & SLA	15%	SOC model, response times, staffing, resilience
Implementation Approach	10%	Transition, timeline, dependencies, change management
Reporting & Analytics	5%	KPIs, KRIs, dashboards, evidence quality
Commercials	15%	Total cost, pricing transparency, contractual assumptions

12. RFP Timeline

Milestone	Date
RFP Issued	September 15, 2026
Vendor Questions Due	September 25, 2026
Responses to Questions	September 30, 2026
Proposal Submission	October 16, 2026
Shortlist Notification	October 30, 2026
Vendor Presentations	November 9–13, 2026
Preferred Vendor Selection	November 20, 2026
Target Contract Start	January 4, 2027

13. Appendix A — Requirement IDs

ID	Requirement	Priority
CS-001	24x7 security monitoring	Mandatory
CS-002	Incident response and escalation	Mandatory
CS-003	Vulnerability management	Mandatory
CS-004	Identity and privileged-access monitoring	Mandatory
CS-005	Cloud security monitoring	Mandatory
CS-006	Customer/claims data protection	Mandatory
CS-007	Third-party cyber-risk management	Mandatory
CS-008	Executive KPI/KRI reporting	Mandatory
CS-009	Security awareness program	Preferred
CS-010	Advanced threat hunting	Preferred

Note: This is a fictional sample RFP created for testing, research-analysis, and proposal-analysis workflows. It is not an actual procurement notice and does not represent the requirements of a real insurer or regulator.